



Weekly IT Security Brief (Official-source-first) | 2026-04-12 06:01

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 2 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-1340(2026-04-11), CVE-2026-35616(2026-04-09). Prioritize internet-facing and privileged systems first.
- Threat trend #1: The agentic SOC—Rethinking SecOps for the next decade. The agentic SOC—Rethinking SecOps for the next decade
- Threat trend #2: Investigating Storm-2755: "Payroll pirate" attacks targeting Canadian employees. Investigating Storm-2755: "Payroll pirate" attacks targeting Canadian employees
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-1340

CVE Title	CVE-2026-1340 ivanti/endpoint_manager_mobile Remote Code Execution
CVE Description	A code injection in Ivanti Endpoint Manager Mobile allowing attackers to achieve unauthenticated remote code execution.
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	ivanti/endpoint_manager_mobile
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-1340

CVE-2026-35616

CVE Title	CVE-2026-35616 fortinet/forticlientems Unknown Type
CVE Description	A improper access control vulnerability in Fortinet FortiClientEMS 7.4.5 through 7.4.6 may allow an unauthenticated attacker to execute unauthorized code or commands via crafted requests.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fortinet/forticlientems
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-09
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-35616

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-5526

CVE Title	CVE-2026-5526 待核實 Unknown Type
CVE Description	A security flaw has been discovered in Tenda 4G03 Pro up to 1.0/1.1/04.03.01.53/192.168.0.1. Affected by this vulnerability is an unknown functionality of the file /bin/httpd. The manipulation results in improper access controls. The attack may be performed from remote. The exploit has been released to the public and may be used for attacks.
Affected Products	待核實
Risk Score	7.3 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-5526

CVE-2026-5527

CVE Title	CVE-2026-5527 待核實 Unknown Type
CVE Description	A weakness has been identified in Tenda 4G03 Pro 1.0/1.0re/01.bin/04.03.01.53. Affected by this issue is some unknown functionality of the file /etc/www/pem/server.key of the component ECDSA P-256 Private Key Handler. This manipulation causes use of hard-coded cryptographic key
Affected Products	待核實
Risk Score	5.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-5527

CVE-2026-5528

CVE Title CVE-2026-5528 | 待核實 | Unknown Type

CVE Description A security vulnerability has been detected in MoussaabBadla code-screenshot-mcp up to 0.1.0. This affects an unknown part of the component HTTP Interface. Such manipulation leads to os command injection. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-5528>

CVE-2026-5529

CVE Title CVE-2026-5529 | 待核實 | Unknown Type

CVE Description A vulnerability was detected in Dromara lamp-cloud up to 5.8.1. This vulnerability affects the function pageUser of the file /defUser/pageUser of the component DefUserController. Performing a manipulation results in improper authorization. The attack can be initiated remotely. The exploit is now public and may be used. The project was informed of the problem early through an issue report but has not responded yet.

Affected Products 待核實

Risk Score 4.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-5529>

CVE-2026-5530

CVE Title	CVE-2026-5530 待核實 SSRF
CVE Description	A flaw has been found in Ollama up to 18.1. This issue affects some unknown processing of the file server/download.go of the component Model Pull API. Executing a manipulation can lead to server-side request forgery. The attack can be launched remotely. The vendor was contacted early about this disclosure but did not respond in any way.
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-5530

CVE-2026-5531

CVE Title	CVE-2026-5531 待核實 Unknown Type
CVE Description	A vulnerability has been found in SourceCodester Student Result Management System 1.0. Impacted is an unknown function of the file /login_credentials.txt of the component HTTP GET Request Handler. The manipulation leads to cleartext storage in a file or on disk. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used.
Affected Products	待核實
Risk Score	5.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-5531



Report B: Threat Intelligence News (last 7 days)

Headline: The agentic SOC—Rethinking SecOps for the next decade

Source	Microsoft Security Blog
Published	Thu, 09 Apr 2026 19:00:00 +0000
Key Takeaway	The agentic SOC—Rethinking SecOps for the next decade
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/09/the-agentic-soc-rethinking-secops-for-the-next-decade/

Headline: Investigating Storm-2755: “Payroll pirate” attacks targeting Canadian employees

Source	Microsoft Security Blog
Published	Thu, 09 Apr 2026 15:00:00 +0000
Key Takeaway	Investigating Storm-2755: “Payroll pirate” attacks targeting Canadian employees
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	financial/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/09/investigating-storm-2755-payroll-pirate-attacks-targeting-canadian-employees/

Headline: CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat

Source	CISA News
Published	Thu, 26 Feb 26 12:00:00 +0000
Key Takeaway	CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-issues-updated-resurge-malware-analysis-highlighting-stealthy-active-threat

Headline: Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN Systems

Source	CISA News
Published	Wed, 25 Feb 26 12:00:00 +0000
Key Takeaway	Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN Systems
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/immediate-action-required-cisa-issues-emergency-directive-secure-cisco-sd-wan-systems

Headline: vSphere and BRICKSTORM Malware: A Defender's Guide

Source Mandiant Blog

Published Thu, 02 Apr 2026 14:00:00 +0000

Key Takeaway This activity is not the result of a security vulnerability in vendors' products or infrastructure. Instead, these intrusions rely on the effectiveness of exploiting weak security architecture and identity design, a lack of host-based configuration enforcement, and limited visibility within the virt Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/laterna...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target defense/global

Technique Phishing

MITRE ATT&CK Unverified

Related CVEs CVE-2026-22769

Link <https://cloud.google.com/blog/topics/threat-intelligence/vsphere-brickstorm-defender-guide/>

Headline: North Korea-Nexus Threat Actor Compromises Widely Used Axios NPM Package in Supply Chain Attack

Source	Mandiant Blog
Published	Tue, 31 Mar 2026 14:00:00 +0000
Key Takeaway	This could enable further software supply chain attacks, software as a service (SaaS) environment compromises (leading to downstream customer compromises), ransomware and extortion events, and cryptocurrency theft over the near term. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/north-korea-threat-actor-targets-axios-npm-package/

Headline: [Video] The TTP Ep. 22: The Collapse of the Patch Window

Source Cisco Talos Blog

Published Fri, 10 Apr 2026 15:29:39 GMT

Key Takeaway In this episode of The Talos Threat Perspective, we discuss how vulnerability exploitation is accelerating, and why attacker speed, AI, and exposed systems are affecting the patch window. 22: The Collapse of the Patch Window Blog Intelligence Center Intelligence Center BACK Intelligence Search Email Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/video-the-ttp-ep-22-the-collapse-of-the-patch-window/>

Headline: The threat hunter’s gambit

Source	Cisco Talos Blog
Published	Thu, 09 Apr 2026 18:00:20 GMT
Key Takeaway	The threat hunter’s gambit Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Emergency S Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-threat-hunters-gambit/

Headline: Citizen Lab: Law Enforcement Used Webloc to Track 500 Million Devices via Ad Data

Source	The Hacker News
Published	Sat, 11 Apr 2026 11:32:00 +0530
Key Takeaway	Hungarian domestic intelligence, the national police in El Salvador, and several U.S. law enforcement and police departments have been attributed to the use of an advertising-based global geolocation surveillance system called Webloc. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	待核實/global
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/04/citizen-lab-law-enforcement-used-webloc.html

Headline: GlassWorm Campaign Uses Zig Dropper to Infect Multiple Developer IDEs

Source	The Hacker News
Published	Fri, 10 Apr 2026 18:53:00 +0530
Key Takeaway	Cybersecurity researchers have flagged yet another evolution of the ongoing GlassWorm campaign, which employs a new Zig dropper that's designed to stealthily infect all integrated development environments (IDEs) on a developer's machine. The technique has been discovered in an Open VSX extension nam Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/l...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/04/glassworm-campaign-uses-zig-dropper-to.html

Headline: In Other News: Cyberattack Stings Stryker, Windows Zero-Day, China Supercomputer Hack

Source	SecurityWeek
Published	Fri, 10 Apr 2026 14:44:53 +0000
Key Takeaway	In Other News: Cyberattack Stings Stryker, Windows Zero-Day, China Supercomputer Hack - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State Ransomwa Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lat...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-cyberattack-stings-stryker-windows-zero-day-china-supercomputer-hack/

Headline: Juniper Networks Patches Dozens of Junos OS Vulnerabilities

Source	SecurityWeek
Published	Fri, 10 Apr 2026 13:44:17 +0000
Key Takeaway	A critical-severity flaw could be exploited remotely, without authentication, to take over a vulnerable device. Juniper Networks Patches Dozens of Junos OS Vulnerabilities - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Thre Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/juniper-networks-patches-dozens-of-junos-os-vulnerabilities/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)